Cybersecurity Incident Report

You work as a security analyst for a travel agency that advertises sales and promotions on the company's website. The employees of the company regularly access the company's sales webpage to search for vacation packages their customers might like.

One afternoon, you receive an automated alert from your monitoring system indicating a problem with the web server. You attempt to visit the company's website, but you receive a connection timeout error message in your browser.

You use a packet sniffer to capture data packets in transit to and from the web server. You notice a **large number of TCP SYN requests** coming from an unfamiliar IP address. The web server appears to be overwhelmed by the volume of incoming traffic and is losing its ability to respond to the abnormally large number of SYN requests. You suspect the server is under attack by a malicious actor.

**You take the server offline temporarily** so that the machine can recover and return to a normal operating status. You also **configure the company's firewall to block the IP address that was sending the abnormal number of SYN requests**. You know that your IP blocking solution won't last long, as an attacker can spoof other IP addresses to get around this block. You need to alert your manager about this problem quickly and discuss the next steps to stop this attacker and prevent this problem from happening again. You will need to be prepared to tell your boss about the type of attack you discovered and how it was affecting the web server and employees

| **Section 1: Identify the type of attack that may have caused this network interruption** |
| --- |
| The most likely explanation for the website's connection timeout errors is a **TCP** |

**SYN flood attack**, which is a type of Denial-of-Service (DoS) attack.

The network logs show a large volume of TCP SYN requests originating from an unfamiliar IP address. This unusual traffic pattern suggests that a malicious actor was attempting to overwhelm the web server by initiating a large number of connection requests.

The attack disrupted the server's ability to establish connections with legitimate users, resulting in the website becoming inaccessible.

## Section 2: Explain how the attack is causing the website to malfunction

When website visitors attempt to establish a connection with the web server, a three-way handshake takes place using the TCP protocol. This process involves three steps:

1. **SYN:** The client sends a synchronisation packet (SYN) to the server to request a connection.
2. **SYN-ACK:** The server responds with a synchronisation-acknowledgement packet (SYN-ACK), indicating that it is ready to establish the connection. The server then waits for the client's final acknowledgement.
3. **ACK:** The client sends an acknowledgement (ACK) back to the server, completing the three-way handshake and establishing the connection.

**Explain what happens when a malicious actor sends a large number of SYN packets all at once:**

The attacker floods the target server with a large volume of SYN requests, potentially using spoofed IP addresses to disguise the source of the traffic.

- The server responds to each SYN request with a SYN-ACK packet and allocates resources to maintain the pending connection.
- The attacker does not send the final ACK packet to complete the handshake.
- The server accumulates numerous half-open connections, eventually filling its connection backlog queue and consuming available resources.
- Legitimate users are unable to establish new connections, resulting in service disruption and website downtime.

**Explain what the logs indicate and how that affects the server:**

The network logs indicate that the attack began to affect the server around log entry 72, where the volume of incoming SYN packets started to increase. This placed additional pressure on the server and began to interfere with normal TCP connections.

By log entry 121, the volume of SYN requests had increased significantly, leaving the web server unable to respond effectively to legitimate connection requests.

This suggests that the server's connection backlog was becoming overwhelmed by incomplete TCP handshakes, resulting in a denial of service for legitimate website users.